

# Supply Chain Security Scorecard

payments-api · Generated 2026-06-04 · Scan 2026-06-04

F

SECURITY GRADE

Posture score: 9.5/100

▲ 7.1 vs prior scan

12 components scanned · 7 findings · 3 actively exploited (KEV) · 0 ransomware-linked

2  
Critical

3  
High

3  
In CISA KEV

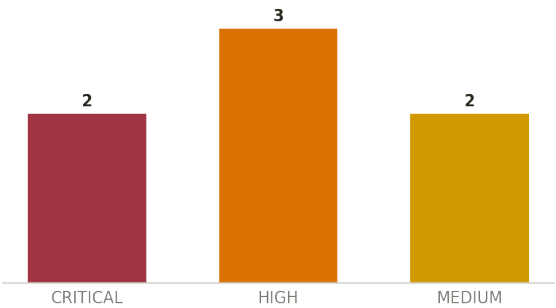
2  
EPSS ≥ 50%

2  
P0 (fix now)

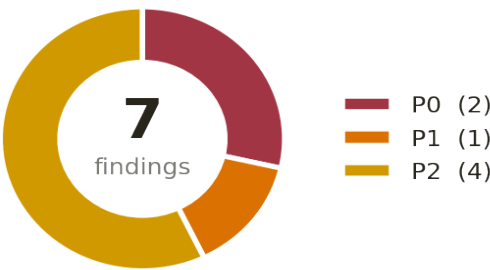
## Executive Summary

This scorecard assesses the software supply chain posture of payments-api across 12 components and 7 vulnerability findings. Prioritization follows a CISA SSVC-aligned model that weighs active exploitation evidence (CISA KEV) and exploit likelihood (FIRST EPSS) above raw CVSS severity. 3 finding(s) appear in the CISA Known Exploited Vulnerabilities catalog and warrant immediate remediation under BOD 22-01 timelines. 2 findings are tier P0 (fix now) and 1 are P1 (fix this cycle). The remaining items are scheduled or monitored.

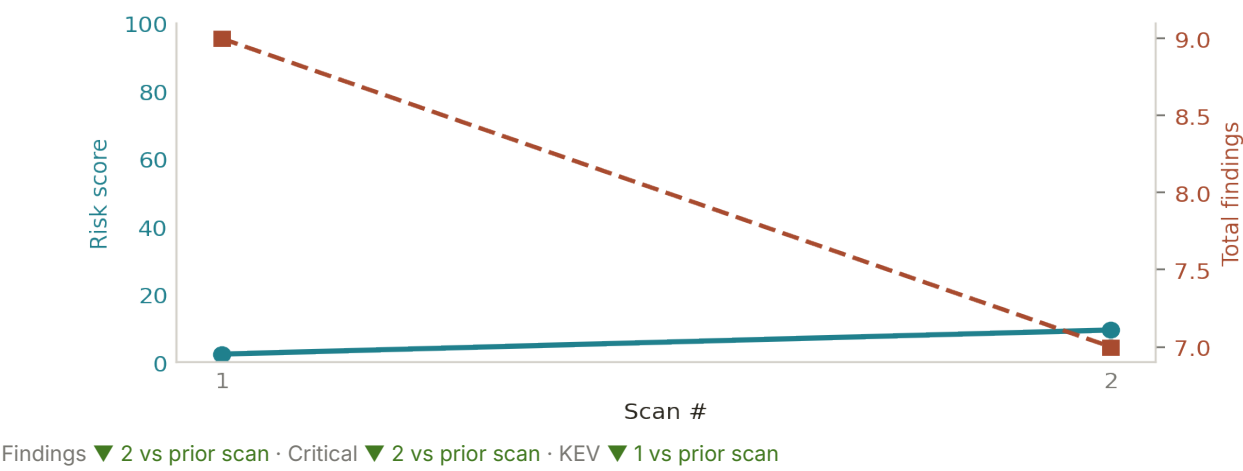
Findings by severity



Priority tier distribution



# Risk Trend Over Time



## Top Offending Components

Components ranked by cumulative priority score (sum of all finding scores). Address the top of this list to remove the most risk per fix.

| # | Component   | Version | Findings | KEV | Worst tier | Risk pts |
|---|-------------|---------|----------|-----|------------|----------|
| 1 | lodash      | 4.17.20 | 2        | —   | P2         | 99       |
| 2 | spring-core | 5.3.16  | 1        | 1   | P0         | 98       |
| 3 | openssl     | 1.0.1c  | 1        | 1   | P0         | 86       |
| 4 | jquery      | 3.4.1   | 1        | 1   | P1         | 61       |
| 5 | curl        | 8.1.2   | 1        | —   | P2         | 59       |
| 6 | zlib        | 1.2.13  | 1        | —   | P2         | 39       |

## Prioritized Remediation Backlog

Top findings ordered by priority score. "Why" summarizes the exploitation signals driving the ranking.

| Tier | Vulnerability                  | Component             | CVSS | EPSS | KEV | Fixed in | Why prioritized                                                                       |
|------|--------------------------------|-----------------------|------|------|-----|----------|---------------------------------------------------------------------------------------|
| P0   | <a href="#">CVE-2022-22965</a> | spring-core<br>5.3.16 | 9.8  | 94%  | ●   | 5.3.18   | Critical severity; High EPSS 94% (likely exploited); In CISA KEV (actively exploited) |
| P0   | <a href="#">CVE-2014-0160</a>  | openssl<br>1.0.1c     | 7.5  | 94%  | ●   | 1.0.1g   | High severity; High EPSS 94% (likely exploited); In CISA KEV (actively exploited)     |
| P1   | <a href="#">CVE-2020-11023</a> | jquery<br>3.4.1       | 6.1  | 35%  | ●   | 3.5.0    | Elevated EPSS 35%; In CISA KEV (actively exploited); Fix available: 3.5.0             |
| P2   | <a href="#">CVE-2023-38545</a> | curl<br>8.1.2         | 9.8  | 27%  | —   | 8.4.0    | High severity; Elevated EPSS 27%; Fix available: 8.4.0                                |
| P2   | <a href="#">CVE-2019-10744</a> | lodash<br>4.17.20     | 9.1  | 19%  | —   | 4.17.12  | Critical severity; Elevated EPSS 19%; Fix available: 4.17.12                          |
| P2   | <a href="#">CVE-2021-23337</a> | lodash<br>4.17.20     | 7.2  | 4%   | —   | 4.17.21  | High severity; Fix available: 4.17.21                                                 |
| P2   | <a href="#">CVE-2023-45853</a> | zlib<br>1.2.13        | 7.8  | 1%   | —   | —        | —                                                                                     |

## Recommended Actions for Engineering

- Patch all 3 CISA KEV finding(s) within BOD 22-01 due dates; treat as the top of the backlog regardless of CVSS.
- Resolve 2 P0 finding(s) this sprint; most have a published fixed version and are quick wins.
- 3 high-priority findings have an available fix — prioritize version bumps for the top offending components above.
- Wire this scorecard into CI to fail builds introducing new P0/KEV findings, and re-run on each release to track the trend line.
- Review CWE/CAPEC attack-pattern context (in the JSON export) to add targeted detections for the most common weakness classes.

---

## Methodology & Data Sources

Priority score (0-100) blends CVSS base severity ( $\leq 50$ ), FIRST EPSS exploit probability ( $\leq 30$ ), and CISA KEV active-exploitation status ( $\leq 20$ , escalated for ransomware use). Tiers: P0  $\geq 80$ , P1  $\geq 60$ , P2  $\geq 35$ , P3  $< 35$ ; any KEV finding is floored at P1.

1. FIRST EPSS API — <https://www.first.org/epss/api>

2. CISA Known Exploited Vulnerabilities Catalog — <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

3. MITRE CWE — <https://cwe.mitre.org/> · MITRE CAPEC — <https://capec.mitre.org/>